

Contents

Security Audit Review — Current Homelab Plan 1

Linux privilege layers 3

Security Audit Review — Current Homelab Plan

```
<div class="audit-eyebrow">Objective review artifact</div>
<h1 class="audit-title">Review of Current Homelab Security Plan</h1>
<p class="audit-text">This review evaluates the current plan described by <code>Trevor Lough</code>
<div class="audit-badges">
  <span class="audit-badge primary">Disposition: Revise and strengthen</span>
  <span class="audit-badge ok">Strongest area: Network segmentation</span>
  <span class="audit-badge warn">Weakest area: Validation evidence</span>
  <span class="audit-badge">Framework lens: NIST CSF 2.0</span>
  <span class="audit-badge">Control lens: CIS Controls v8</span>
  <span class="audit-badge">Protocol refs: RFC 1918 / RFC 4193</span>
</div>
```

Rating methodology reference

Rating area	Scale used	Meaning	Source
NIST CSF 2.0 implementation tier	Tier 1–4	Tier 1 = Partial, Tier 2 = Risk-Informed, Tier 3 = Repeatable, Tier 4 = Adaptive	NIST Cybersecurity Framework
CIS Controls v8 maturity	Level 1–5 (internal mapping)	Internal scoring shorthand used to describe how completely the documented controls appear to be implemented and evidenced; this is an audit-layer maturity summary, not an official CIS numeric scale	CIS Controls v8 Overview

Rating area	Scale used	Meaning	Source
CIS Controls v8 implementation groups	IG1-IG3	IG1 = basic cyber hygiene, IG2 = additional protections for more complexity, IG3 = mature protections for higher-risk environments	CIS Implementation Groups
NIST CSF function status language	Weak / Partial / Moderate / Strong	Plain-language reviewer shorthand used to summarize how well the current plan addresses a CSF function based on the evidence present in the document	NIST CSF 2.0 Core
Objective evidence strength	Low / Emerging / Established	Reviewer shorthand for how much validation evidence is actually included, such as diagrams, rule matrices, logs, captures, test records, and recovery proof	NIST Cybersecurity Framework

Scoring note: This review now uses NIST CSF 2.0 implementation tiers as the primary maturity language and CIS Controls v8 as the control-family and implementation-group lens.

```

<div class="audit-panel">
  <h3>What the current plan does well</h3>
  <p>The plan is strongest in segmentation, internal boundary control, and reduction of easy
</div>
<div class="audit-panel">
  <h3>What the current plan does not yet prove</h3>
  <p>The writeup does not yet provide objective validation artifacts such as rule exports, p
</div>

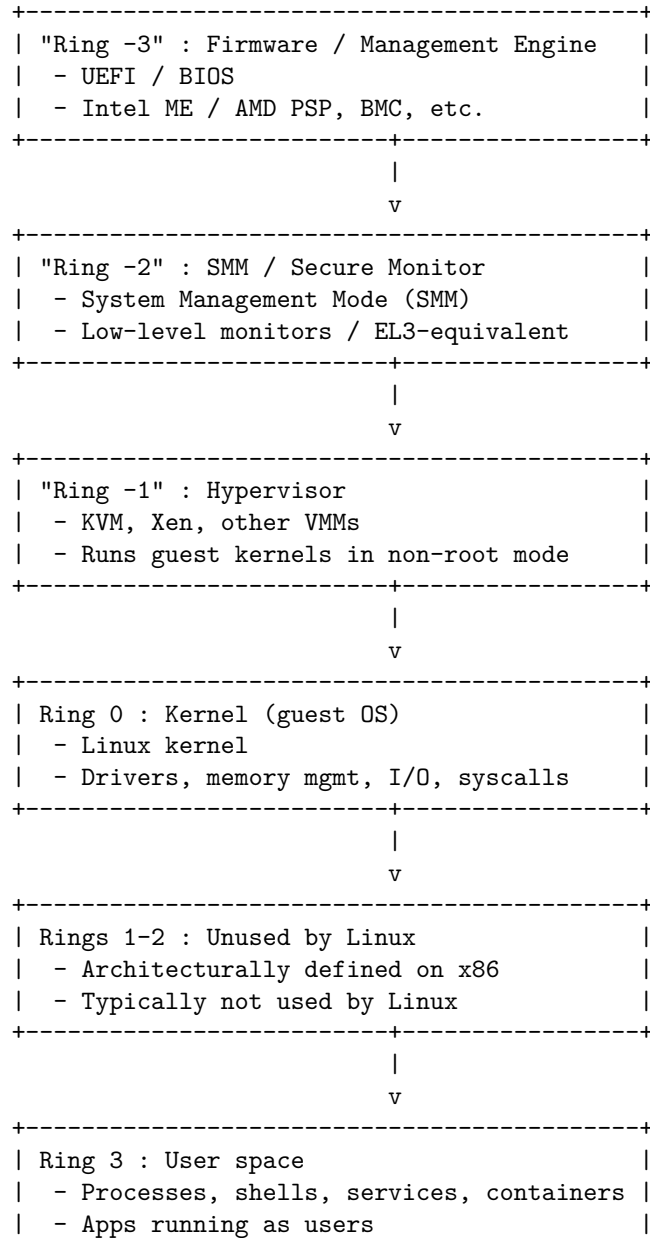
```

```

<div class="audit-panel">
  <h3>Overall assessment</h3>
  <p>The design intent is better than the documentation quality. The network policy model ap

```

Linux privilege layers



+-----+

Framework-based scorecard

```
<div class="audit-score">
  <div class="audit-score-head"><span>Identify (NIST CSF) & Network (CIS)</span><span class="audit-pill">3 / CIS Level ~2-3</span></div>
  <div class="audit-meter"><span style="width:80%"></span></div>
  <p>VLAN segmentation, admin-device exceptions, and DMZ separation are meaningful controls</p>
</div>
<div class="audit-score">
  <div class="audit-score-head"><span>Access control (NIST/CIS)</span><span class="audit-pill">Tier 1</span></div>
  <div class="audit-meter"><span style="width:60%"></span></div>
  <p>The plan shows partial least-privilege thinking through aliases and narrow exceptions,</p>
</div>
<div class="audit-score">
  <div class="audit-score-head"><span>Detect (NIST CSF)</span><span class="audit-pill">Tier 1</span></div>
  <div class="audit-meter"><span style="width:60%"></span></div>
  <p>Suricata and Zenarmor add meaningful detection capability, but the report does not yet</p>
</div>
<div class="audit-score">
  <div class="audit-score-head"><span>Recover (NIST CSF)</span><span class="audit-pill">Tier 1</span></div>
  <div class="audit-meter"><span style="width:20%"></span></div>
  <p>The current plan does not document backups, restore testing, incident recovery workflow</p>
</div>
<div class="audit-score">
  <div class="audit-score-head"><span>Auditability (CIS / NIST)</span><span class="audit-pill">Tier 1</span></div>
  <div class="audit-meter"><span style="width:20%"></span></div>
  <p>The report contains many claims of effect, but almost no direct evidence, measurements,</p>
</div>
```

Objective control mapping

Plan element | Observed strength

Objective weakness

Recommendation |

|—|—|—|—| | Dual 10G physical separation for trusted vs. DMZ traffic | Strong boundary separation concept that reduces accidental mixing of trust zones. | The report does not show interface diagrams, switchport assignments, or verification that traffic cannot bypass intended separation. | Add deployment-specific notes here. | | VLAN segmentation into management, trusted, private servers, DMZ, and IoT/guest | Good segmentation pattern consistent with reducing lateral movement and scoping exposure. | No rule matrix, inter-VLAN flow table, or validation test results are shown. There is also no asset inventory tied to each VLAN. | Add VLAN-specific findings here. | | RFC1918-based internal block rules | Good default-deny intent for IPv4 internal traffic between zones. | RFC 1918 applies to IPv4 private space only, so the report must clearly separate

IPv4 logic from IPv6 logic and show rule parity. | Add IPv4 rule review notes here. | | Admin device alias for management access | Better than broad subnet trust because it narrows privileged access to named systems. | IP-based trust is not the same as identity assurance; no MFA, device health, certificate trust, or admin session controls are documented. | Add admin-plane concerns here. | | Native LAN lock to network hardware alias | Strong anti-misuse idea for untagged infrastructure ports. | The report does not prove port-security behavior, switch configuration, or what happens during switch replacement, emergency maintenance, or mispatching. | Add switch and port validation notes here. | | DMZ to private-server micro-allowlisting | Strongest control in the writeup because it scopes cross-zone exposure to named application paths. | No service dependency map, allowed-port inventory, or validation test is included, and no host-layer hardening is documented for the allowlisted targets. | Add service-path review notes here. | | Forced DNS via NAT redirect on port 53 | Useful for traditional DNS control and policy enforcement. | The report does not discuss DNS over HTTPS, DNS over TLS, QUIC-based bypass paths, or how exceptions are detected and blocked. | Add DNS bypass observations here. | | IPv6 ULA with NAT66 | Shows awareness that IPv6 must be governed explicitly and separately. | The report should justify NAT66 operationally, define policy parity with IPv4, and explain residual risks and tradeoffs. | Add IPv6 architecture notes here. | | Zenarmor NGFW on internal interfaces | Adds application visibility and policy depth beyond port-level filtering. | No evidence is shown for policy sets, exception handling, update cadence, or how detection output feeds response. | Add DPI policy notes here. | | Suricata IPS on WAN/DMZ edge | Appropriate perimeter detection and block control for exposed services. | No description of ruleset source, tuning, alert fatigue handling, or packet-drop validation is provided. | Add IPS tuning notes here. | | GeoIP restrictions on WAN forwards | Can reduce opportunistic scan exposure. | GeoIP is only a coarse filter; it is not identity, and it is bypassable through VPNs, proxies, and cloud egress regions. The report overstates its effect with “99%” language without measurement evidence. | Add exposure-reduction notes here. |

Strengths

```
<div class="audit-card">
  <strong>1. Segmentation is intentional rather than cosmetic.</strong>
  <p>The current plan separates management, user, server, public, and untrusted device roles
  <details><summary>Reviewer comment area</summary><textarea placeholder="This segmentation
</div>
<div class="audit-card">
  <strong>2. The plan uses default-deny thinking for east-west traffic.</strong>
  <p>The described RFC1918 block model and app-specific exceptions reflect a genuine least-p
  <details><summary>Reviewer comment area</summary><textarea placeholder="The default-deny a
west traffic is one of the most valuable controls in this design. To preserve that strength
</div>
<div class="audit-card">
  <strong>3. The plan recognizes IPv6 as a separate policy domain.</strong>
```

<p>Many otherwise competent network writeups ignore IPv6 entirely; this one does not. The

<details><summary>Reviewer comment area</summary><textarea placeholder="Treating IPv6 as a

</div>

<details><summary>Reviewer comment area</summary><textarea placeholder="Add public-service

Weaknesses

<details><summary>Reviewer comment area</summary><textarea>Please replace broad outcome cla
 <details><summary>Reviewer comment area</summary><textarea> The current writeup focuses on
 <details><summary>Reviewer comment area</summary><textarea> "Network policy is well develo
 <details><summary>Reviewer comment area</summary><textarea> "The plan schematic needs to s
 <details><summary>Reviewer comment area</summary><textarea> "Some phrases read more like m

Recommended objective metrics

Control area	Metric to add	Why it matters
VLAN segmentation	Number of authorized inter-VLAN flows vs. denied flows per review period	Demonstrates that segmentation is defined and measured rather than assumed.

6

Control area	Metric to add	Why it matters
Admin access	Count of management interfaces exposed; count of systems allowed to reach them	Shows whether privileged access scope is minimized.
DNS enforcement	Percentage of DNS requests observed through approved resolver path; count of blocked direct DNS attempts	Validates whether “forced DNS” is actually working.
Suricata	Alerts per day, true-positive rate after tuning, drop count for relevant signatures	Converts IPS claims into measurable operational effectiveness.
Zenarmor	Blocked application categories, exceptions granted, update cadence	Shows whether L7 policy is governed and maintained.
Public exposure	Number of WAN-exposed services, allowed source countries, authentication controls per service	Makes internet exposure concrete and reviewable.
Recovery	Backup frequency, restore test frequency, last successful restore date	Addresses resilience, not just prevention.
Change control	Firewall rule review interval, number of stale rules removed, documented exceptions	Prevents segmentation drift over time.

Standards and reference corrections

```

<div class="audit-card">
  <strong>RFC 1918 usage</strong>
  <p>Use RFC 1918 only when referring to the IPv4 private ranges 10.0.0.0/8, 172.16.0.0/12,
  <details><summary>Reviewer comment area</summary><textarea placeholder="Add IPv4 standards
</div>
<div class="audit-card">
  <strong>IPv6 ULA usage</strong>
  <p>Use RFC 4193 when discussing Unique Local IPv6 Unicast Addresses. If NAT66 remains part
  <details><summary>Reviewer comment area</summary><textarea placeholder="Add IPv6 standards
</div>
<div class="audit-card">

```

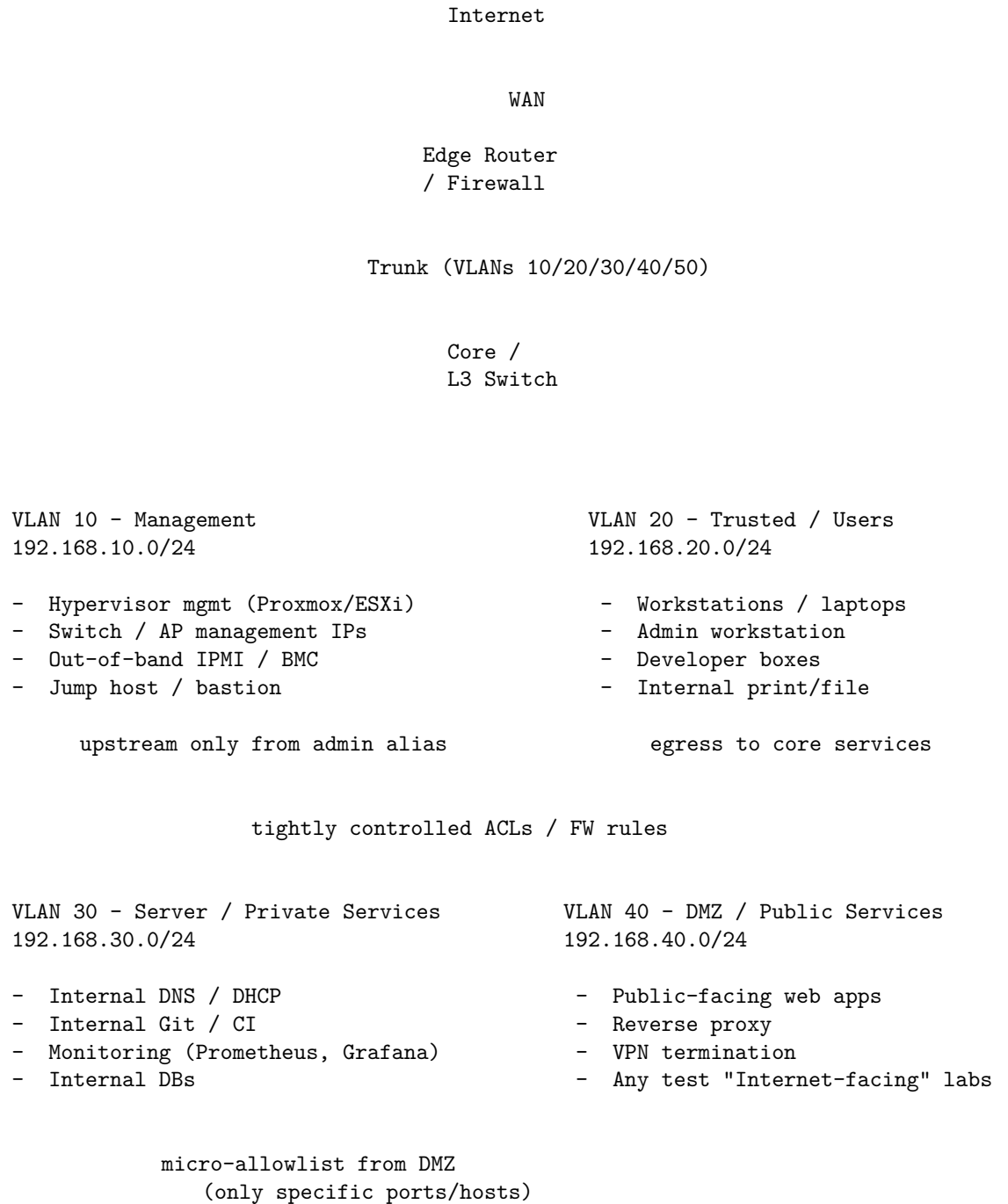
Compliance wording
 Do not imply FIPS, NIST, or similar compliance from architecture quality alone. If a co
 details><summary>Reviewer comment area</summary><textarea placeholder="Add compliance-lar
 </div>

Framework alignment summary

Framework area	Current status	Notes
NIST CSF — Identify	Partial	Zones and asset roles are implied, but formal asset inventory and dependency mapping are not shown.
NIST CSF — Protect	Moderate	Segmentation and filtering are the strongest documented areas.
NIST CSF — Detect	Partial	IPS and NGFW are present, but alert operations are undocumented.
NIST CSF — Respond	Weak	No incident workflow, ownership, or escalation path is described.
NIST CSF — Recover	Weak	No backup, restore, or resilience testing evidence is described.
CIS Controls v8 — Network infrastructure management	Moderate	Good control intent, weak evidence and maintenance documentation.
CIS Controls v8 — Access control management	Partial	Alias-based narrowing exists, but identity assurance and admin governance are thin.
CIS Controls v8 — Audit log management	Weak	Logging and review workflow are not documented.
CIS Controls v8 — Secure configuration	Partial	Configuration intent is strong, but baselines and change control are not shown.

Reviewer guidance:
 The current plan should be graded as a promising technical design that needs a more rigorous

Example homelab network diagram



east-west default-deny between VLANs

VLAN 50 - IoT / Guest
192.168.50.0/24

- Smart TVs, cameras
- Guest Wi-Fi clients
- Other untrusted devices

- Only allowed out to:
 - Internet (via FW rules)
 - Very specific internal services (if needed)
- No direct reachability to Management or Server VLANs